



CNNIC / MCS Holdings incident

By: Jason Man, Dominic Yeakel



Background

China Internet Network Information Center (CNNIC) is a national internet registry under China's Ministry of Industry and Information Technology. They oversee domain registration, internet resource management, and technical standards.



Mideast Communication Systems (MCS) Holdings is/was an IT services provider contracted by CNNIC to operate as an intermediate certificate authority issuing certificates only for internal corporate domains.





Root Cause



1. Improper Delegation of Certificate Authority

CNNIC issued an intermediate certificate to MCS Holdings with unrestricted signing power

2. Insecure Private Key Handling

MCS stored the private key on a firewall device configured as a MITM proxy

3. Unauthorized Certificates Issues

The MITM proxy issued fraudulent certificates





Discovery & Response



- On March 20, 2015, Google discovered unauthorized digital certificates for its own domains, detecting through public-key pinning technology built into Chrome
- **Revocation** - Google pushed an emergency update to Chrome's CRLSet which globally blacklisted the MCS intermediate certificate before widespread interception could occur.
- Dropped CNNIC's root certificates from its products entirely





Lessons Learned



- CAs can no longer rely on legal agreements to restrict how a delegated certificate is used
- Private PKI for Internal Monitoring- If a company inspect its employees' web traffic for malware or data leaks, it needs to build its own internal CA
- Push for a standard where all certificate issuance is publicly logged and auditable

